

5.1 Network Security Basics

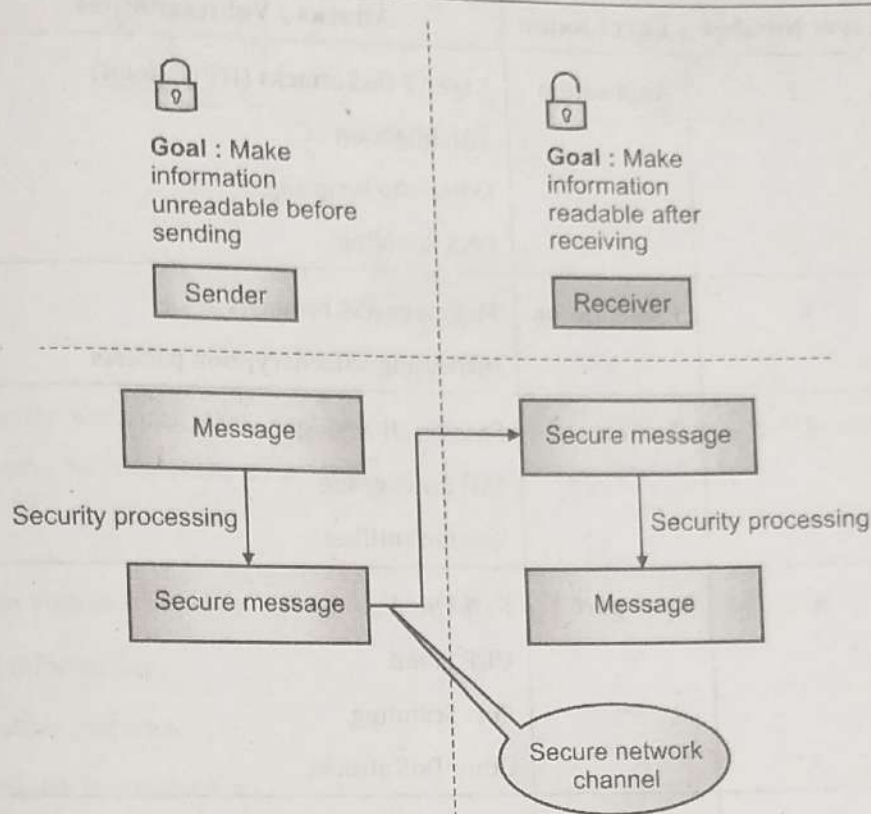


Fig. 5.1.1 : Transmitting a Message Securely over a Network

Network channel and protocols play a crucial role in information security. The information is not very useful when just stored locally on a computer. It must move to different devices in its lifetime to be useful. The way information is transferred from one device to another depends on several networking parameters. **Look at the simplistic diagram here.**

The network channel is the core mechanism to ensure that the message is transferred securely. If there are network vulnerabilities, as you will learn in this chapter, the information cannot be reliably sent.

You might have a question – if you are already securing the message before sending, why do you need a secure channel as well? The answer is that if the message can be intercepted (picked up) from the channel, the secure message can be attacked such that to make it insecure. Consider an example. You seal your letter in an envelope. But, if the person carrying the envelope is not reliable enough, would you still send the envelope with her? Not really, right? Same way, the network medium (or channel) should be secure enough to transfer the message to the destination reliably.

5.2 TCP/IP Vulnerabilities (Layer Wise)

Recall from our previous discussion on OSI model that you can conceptually view the networking as seven layers that inter-operate. Each of these layers have their respective vulnerabilities and requires appropriate protection mechanism. Some of these attacks and vulnerabilities are highlighted in the Table 5.2.1.

Table 5.2.1 : TCP/IP Vulnerabilities (Layer Wise)

Layer Number	Layer Name	Attacks / Vulnerabilities
7	Application	Layer 7 DoS attacks (HTTP flood) SQL Injection Cross-site scripting DNS Spoofing
6	Presentation	Malicious SSL requests Inspecting SSL encryption packets
5	Session	Session Hijacking SSH downgrade Session sniffing
4	Transport	SYN Flood UDP Flood Port Scanning Other DoS attacks
3	Network	IP Spoofing Source Address Spoofing ICMP Flood Packet Sniffing Teardrop attack Other DoS attacks
2	Data Link	ARP Flooding ARP Spoofing MAC flooding DHCP Spoofing
1	Physical	Wire-cuts Disrupting the signal Any other media transmission disturbance

Let's learn a few of these in detail.

5.2.1 Packet Sniffing

Definition : Packet Sniffing is the act of intercepting (capturing) of network traffic and logging it for further analysis.

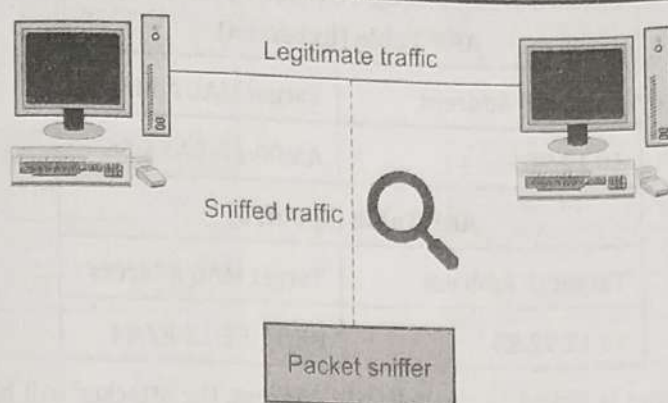


Fig. 5.2.1 : Packet Sniffing

Packet sniffing is carried out using either software programs or hardware devices. These are called packet analysers or just packet sniffers. Wireshark is one of the most widely used Packet Sniffing program.

Common Attacks

Some of the common attacks carried out using packet sniffing technique are as following:

- Capturing sensitive information.
- Analyse communication patterns.
- Learn about the network infrastructure.
- Exploit network vulnerabilities.

Protection

You cannot, to a great extent, avoid network sniffing attempts since it is external to the network and mostly beyond your control. For example, how do you protect someone with Wi-Fi analysing device to capture your Wi-Fi packets? However, some of the common protection mechanisms to reduce the impact from sniffing are as follows:

- **Encryption** : Use TLS, VPN tunnels or application level encryption wherever possible to avoid sending and receiving data in plaintext.
- **Use secure protocols** : Discourage the use of protocols such as HTTP, FTP, TELNET, RPC and prefer using secure protocols such as HTTPS, FTPS, SSH, etc.
- **Isolate and Segment Networks** : Design your network in such a way that the sensitive systems are adequately segmented from rest of the network.

5.2.2 ARP Spoofing

✗ **Definition** : ARP spoofing is a technique by which the attacker associates her MAC address with the IP address of a legitimate device.

It is also called ARP cache poisoning or ARP poison routing.

During network communication, a device, when wishes to interact with another target device, requires mapping the IP address of the target to the MAC address of the target. In ARP spoofing, the attacker maliciously provides MAC address of her device so that the wrong mapping of target IP address to target MAC is created.

ARP Table (Expected)	
Target IP Address	Target MAC Address
10.12.92.56	AA:00:FE:12:E4:56
ARP Table (Spoofed)	
Target IP Address	Target MAC Address
10.12.92.56	BB:11:FE:12:F7:84

Once the attacker's MAC address is linked to the target IP address, the attacker will begin receiving any data that is intended for that IP address. ARP spoofing can enable malicious parties to intercept, modify or even stop data in-transit. ARP spoofing attacks can only occur on local area networks that utilize the Address Resolution Protocol (ARP).

Common Attacks

Some of the common attacks carried out using ARP spoofing technique are as following:

- **Denial-of-service attacks** : DoS attacks often use ARP spoofing to link multiple IP addresses with a single target's MAC address. As a result, traffic that is intended for many different IP addresses will be redirected to the target's MAC address, overloading the target with traffic.
- **Session hijacking** : Session hijacking attacks can use ARP spoofing to steal session IDs and thus granting attackers access to private or sensitive data.
- **Man-in-the-middle attacks** : MITM attacks can use ARP spoofing to intercept and modify traffic between victims and carry out further attacks.

Protection

Some of the protection mechanisms for ARP spoofing are as follows:

- **Static ARP entries** : You could create static ARP entries so that any MAC entries are approved for use.
- **ARP spoofing detection software** : You could use software to detect ARP spoofing attacks and prevent spoofed MAC entries.

5.2.3 Port Scanning

Q. What is Authentication Header (AH)? How does it protect against replay attacks?

MU - May 19, 5 Marks

In computer networking terminology,

✍ **Definition** : A port is an endpoint of communication that serves the service requests.

Each service on the OS requires a port to communicate with any other service or device on the network. Hence, indirectly, if you can find out which ports are open for connection on a particular system, it is as good as knowing which services are running on the system. Once you know which services are running on the system, you can further craft attacks on the system exploiting vulnerabilities in those services.

Hence,

✍ **Definition** : Port scanning is a technique using which you can identify the state of ports and indirectly know about the running services that could be exploited.

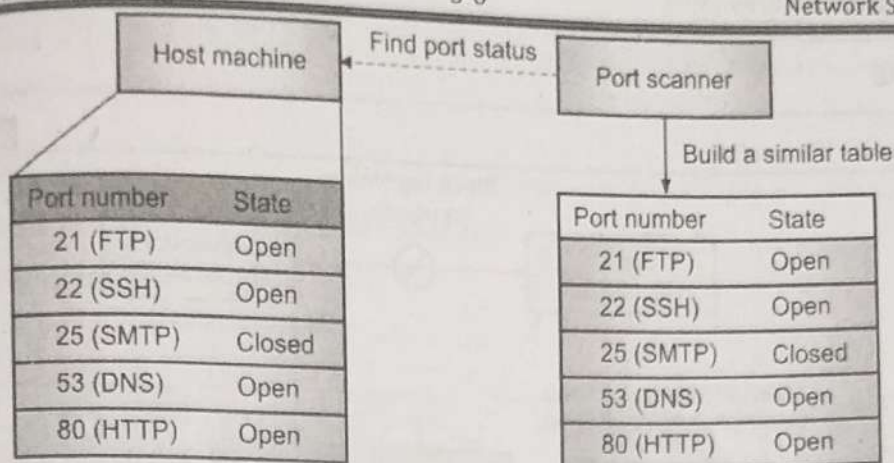


Fig. 5.2.2 : Port Scanning

5.2.3(A) Port Scanning Techniques

There are several port scanning techniques. The following techniques are commonly used.

1. Connect Scan
2. SYN Scan
3. FIN Scan
4. NULL Scan

Let's learn about them.

1. **Connect Scan** : This is the simplest of all the port scanning techniques. The port scanner utilizes the OS network functions to identify any open ports. It tries to establish the connection to all the ports serially one after the another. The ports that are open would complete the 3-way TCP handshake and ports which are not open would not.
2. **SYN Scan** : In this technique, the port scanner sends the SYN packet to the ports it desires to test openness for. Ports that are open respond with SYN-ACK packet and ports that are not open respond with RST packet.
3. **FIN Scan** : In this technique, the port scanner sends the FIN packet to the ports it desires to test openness for. Ports that are open ignore the packet and ports that are not open respond with RST packet.
4. **NULL Scan** : In this technique, the port scanner sends a TCP packet with no TCP flags set. Ports that are open ignore the packet and ports that are not open respond with RST packet.

Protection

1. **Close unnecessary ports** : Close unnecessary ports on the system. Any service that you are not using and is installed and running could be vulnerable to attacks.
2. **Firewalls** : Firewalls can stop scanning or connection establishment from any non-approved devices. They can filter various ports and avoid providing the state of the ports to any unauthorized port scanners.
3. **Intrusion Detection Systems** : Intrusion Detection Systems can identify port scanning attempts and can raise notifications accordingly.

5.2.4 IP Spoofing

Q. Write in brief about - IP spoofing.

MU - Dec. 15, 5 Marks

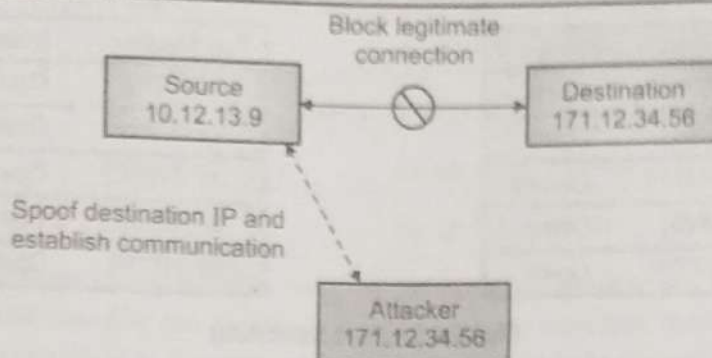


Fig. 5.2.3 : IP Spoofing

IP addresses are, in a way, identities of the systems that are communicating over a network.

✍ **Definition :** IP Spoofing is a technique whereby an attacker impersonates (tries to steal the identity of) another machine by manipulating IP packets.

The goal of the attacker is to get unauthorized access to communication by manipulating her IP address as the actual target IP address.

Common Attacks

Some of the common attacks carried out using IP spoofing technique are as following:

- Steal sensitive information by impersonating as the legitimate IP address.
- Bypass authentication in networks where machines are trusted by their IP addresses.
- Carry out of Denial of Service (DoS) attacks by manipulating that the traffic is coming from a legitimate source.

Protection

Some of the protection mechanisms for IP spoofing are as follows:

- Do not trust IP addresses for authentication. Use stronger form of authentication such as certificates.
- Use packet filtering to reject packets with private (internal) IP addresses.
- Monitor network using controls such as network monitoring tools, IDS, etc.

5.2.5 Denial of Service (DoS) and Distributed Denial of Service (DDoS)

Q. What is a Denial of service attack? What are the different ways in which an attacker can mount a DOS attack on a system?

MU - Dec. 15, May 17, 10 Marks

Q. Write in brief about Denial of service attacks.

MU - May 16, 5 Marks

Q. Explain briefly with example, How the following Denial of service attacks occurs.

MU - Dec. 16, Dec. 17, 5 Marks

Q. Explain different types of Denial of Service attacks.

MU - May 19, 10 Marks

Remember our discussion on availability - one of the CIA triads? DoS and DDoS are attacks on the availability triad.

Definition : Denial of Service (DoS) is an attack from a single source such that the resources are exhausted on the target beyond its serving capacity.

Definition : Distributed Denial of Service (DDoS) is an attack from multiple sources such that the resources are exhausted on the target beyond its serving capacity.

Let's understand these using quick examples.

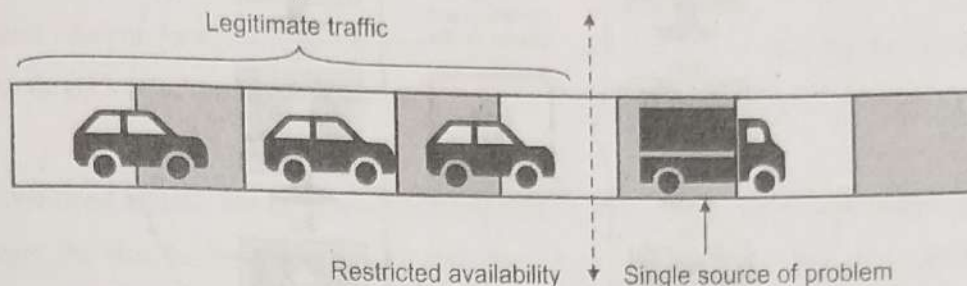


Fig. 5.2.4 : Analogy for DoS

In this example, a single source (truck – the attack) is blocking the road (resources) for all other vehicles (legitimate traffic) behind it.

The vehicles behind the truck have limited mobility and the road (resources) is exhausted (full capacity being consumed by the truck). This is what is DoS in the typical sense. A single source of attack exhausts all target resources such that the target is unavailable to serve the legitimate requests.

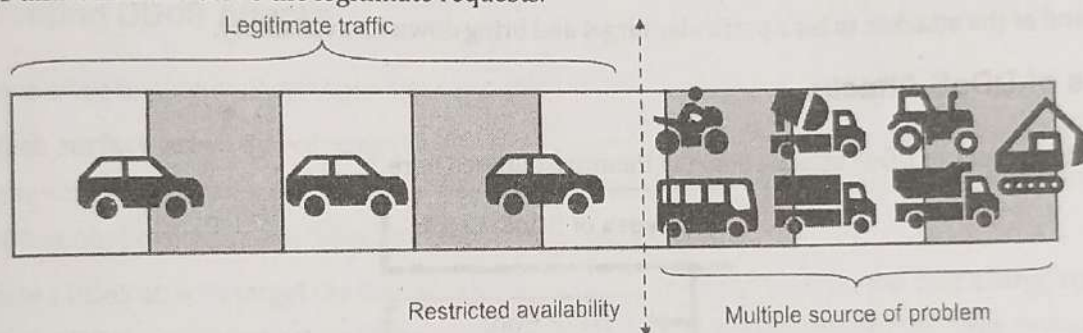


Fig. 5.2.5 : Analogy for DDoS

In the second example, there are multiple sources of jam (attacks) that have completely blocked the road (resources) despite that the road is wider this time when compared with the previous example. This is what is typically Distributed Denial of Service (DDoS).

Note : These days computer and other equipment have large capacities. So, it is not very effective to carry out DoS attack (the resources are sufficient to not cause any availability problem). Instead, attackers choose DDoS to attack the target such that to exhaust its capacity (such that even a larger capacity does not help to protect availability to a great extent). Hence, in our discussion, we can use the terms DoS and DDoS to actually mean just DDoS. Any DDoS attack is actually a DoS attack which is amplified (multiplied) using various sources of attack.

5.2.5(A) Botnet

Understanding botnet (robot networks) is crucial to understating DDoS attacks.

Definition : A botnet refers to a group of computers which have been infected by an attacker and is under her complete control.

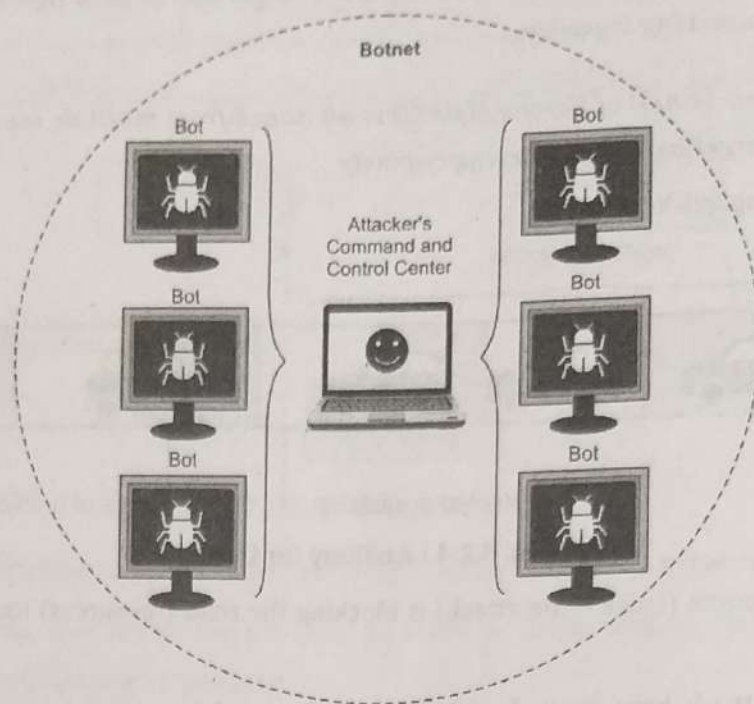


Fig. 5.2.6 : Botnet

These are the computers that the attacker uses to carry out DDoS attacks. All the computers in the group work together under the command of the attacker to hit a particular target and bring down its availability.

5.2.5(B) Types of DDoS Attacks

There are various types of DDoS attacks. Some of them are outlined here.

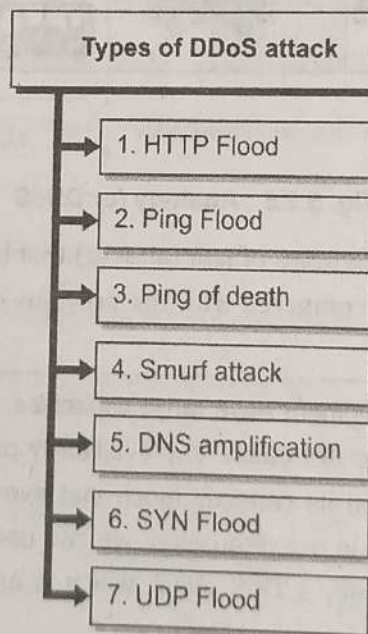


Fig. 5.2.7 : Types of DDoS Attacks

1. **HTTP flood** : HTTP flood is similar to you hitting refresh on your browser several times. It is just that it is done at a much large scale to crash the webserver and restrict the legitimate users from reaching the webserver.
2. **Ping (ICMP) Flood** : In this attack, the target machine is sent so many ping requests that it is overwhelmed and fails to respond.

3. **Ping of Death** : In this attack, the target machine is sent malformed packets such that the system is unable to understand and process them resulting into system crash.
4. **Smurf attack** : The victim's IP address is used as the recipient for receiving responses from broadcast communication. The attacker then crafts a request such that all the computers in a network respond to the victim's IP address such that it is overwhelmed and crashes.
5. **DNS Amplification** : As you know, DNS server resolves the domain name to an IP address. The attacker crafts a DNS request (with the target's IP address) such that the DNS server responds with a large amount of data and crashes the target.
6. **SYN Flood** : In SYN flood attacks, the attacker exploits the way a TCP connection is established. After sending the SYN packet to the target, the attacker does not respond with the ACK packet. The target keeps on waiting for the ACK until it runs out of the resources. The attacker sends multiple such SYN packets until the resources on the target are totally consumed and the target can no more receive any SYN packets further.
7. **UDP flood** : UDP flood occurs when the target receives multiple UDP packets and it needs to check if there are any UDP ports listening for UDP traffic. It wastes a lot of target resources in conducting such searches for port numbers and thus the target becomes too busy to serve any legitimate traffic thus impacting its availability.

5.2.5(C) Preventing DDoS Attacks

Here are some ways to potentially prevent DDoS attacks.

1. **Reduce attack surface area** : By reducing the attack surface area we mean reducing the number of points exposed for attacks. These could be network ports, number of services running, open networks, unrestricted administrative access, unpatched OS or applications or anything else that could be exploited.
2. **Plan for scale** : DDoS attacks target the limited resources. If you have resources spread over a large scale (or say cloud computing), the DDoS attack impact could be very minimal and could be absorbed by the large resource pool without impacting availability.
3. **Know what is a normal and an abnormal traffic** : Knowing your network traffic patterns would let you plan for action if you see any change in the pattern that signals that you are under attack. You can then appropriately take actions to remedy any impact from DDoS.
4. **Deploy firewalls** : DDoS attacks are mostly network based. Having stringent (strong) firewall rules, such that only appropriate traffic is allowed, is a great way to ensure that the resources are not wasted in serving the DDoS traffic. Only the traffic that is legitimate is allowed on the network. Rest all the traffic is dropped without impacting the resources.

5.3 Internet Security Protocols

World Wide Web or just web is a collection of web servers that run several websites that hold the desired information. The Internet as a whole is a collection of such servers and various communication devices and protocols. You mostly use browsers (such as Chrome, Firefox, Internet Explorer, Safari, etc.) or applications (for example, Mobile Apps) to browse the web and fetch the desired information or just complete a desired interaction such as making a purchase.

- Mutual authentication of the communicating entities.
- Negotiating cryptographic parameters.
- Creating session keys.

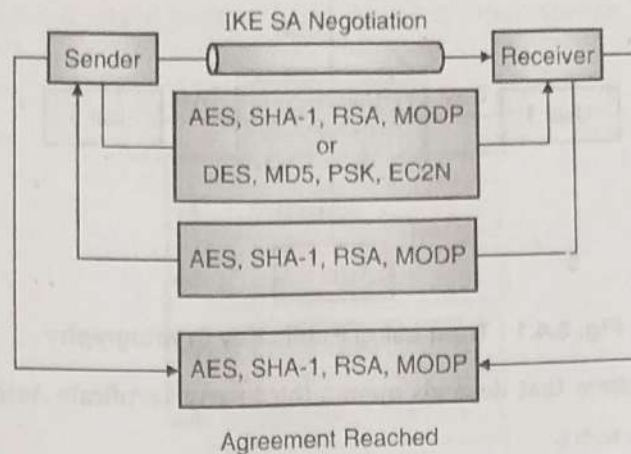


Fig. 5.3.21 : IKE Agreement Process

In Phase 2, an IPSec tunnel is negotiated by creating keying material for the IPSec tunnel to use (either by using the IKE phase one keys as a base or by performing a new key exchange).

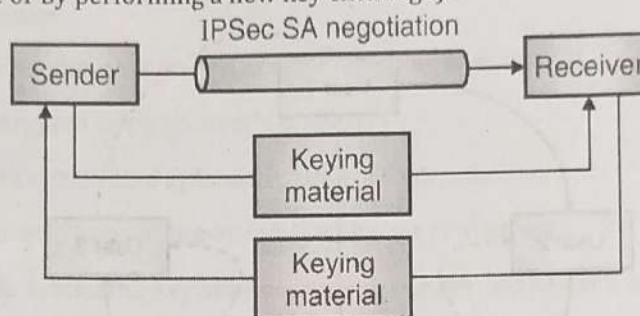


Fig. 5.3.22 : IPSec Tunnel Negotiation

5.4 Secure Email

Q. Write in brief about Email security.

MU - May 16, 5 Marks

Around billions of emails are sent across the globe every day. Emails have become the primary source of official communication. With such a wide use of emails, attackers are inclined and motivated to intercept emails and get the message and at times modifying the messages before the recipient gets it. It is important that you secure the email communication as any other form of communication. In this section, you will learn about a couple of email security standards that you could use.

5.4.1 Pretty Good Privacy (PGP)

Q. How does PGP achieve confidentiality and authentication in emails?

MU - Dec. 15, 5 Marks

Definition : Pretty Good Privacy (PGP) is an email security program that was developed in 1991. It is based on public key cryptography.

1. Web of Trust

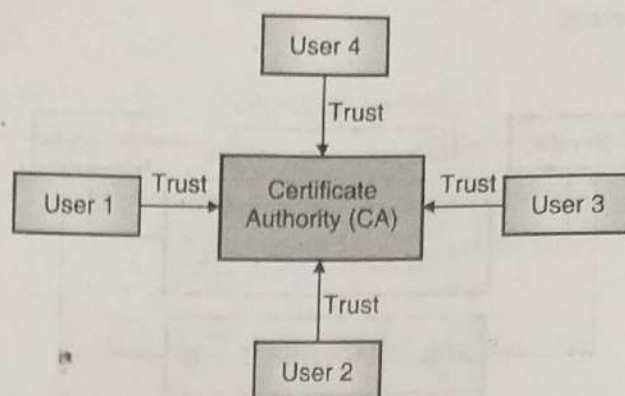


Fig. 5.4.1 : Trust using Public Key Cryptography

In Public Key Cryptography system that depends upon a third-party Certificate Authorities (CAs) to establish trust, there is no mutual trust amongst the users.

Each user trusts a reputed CA and thus CA plays a predominant role in establishing the trust so that communication can happen between users. If there is no CA, the trust relationship is not established and thus the communication may not happen.

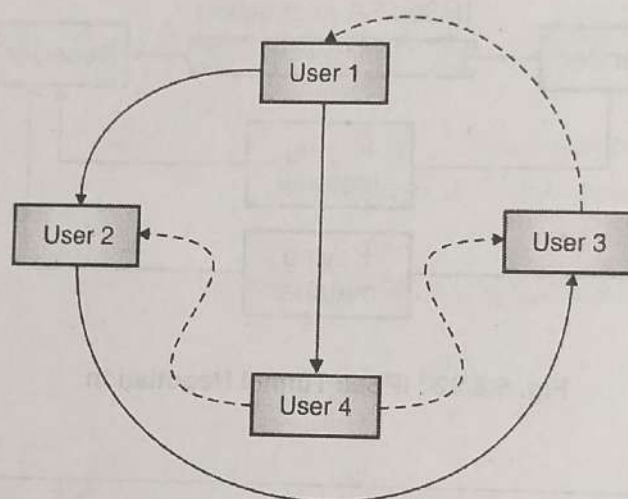


Fig. 5.4.2 : Web of Trust

Unlike the traditional Public Key Cryptography system that depends upon a CA to establish trust amongst the users, the earlier implementations of PGP did not use the regular CAs for issuing certificates. It used "Web of Trust" where each user generates and distributes his or her public key, and users sign each other's public keys, which creates a community of users who trust each other. This is different from the CA approach, where no one trusts each other; they only trust the CA.

So, basically, PGP is a system of "I don't know you, but my friend Alice says that you can be trusted, so I will trust you on her words". In the Fig. 5.4.2, as you understand, there is a trust relationship (User 1, User 2) and (User 2, User 3). Now, when User3 needs to communicate with User 1, it establishes a trust inherited from its prior trust on User 2. There is no third-party involved in this scenario. Each user keeps in a file, referred to as a key ring, a collection of public keys he has received from other users. Each key in that ring has a parameter that indicates the level of trust assigned to that user and the validity of that particular key.

5.4.1(A) PGP Services

PGP provides the following services. You can use one or more services at a time. For example, if you intend to use only encryption service, you can do so. If you intend to use only the digital signature service, you can do so. Let's learn a brief about these services.

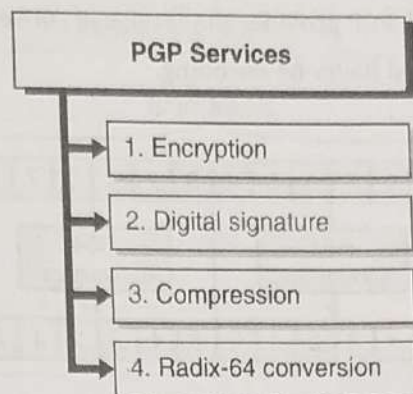


Fig. 5.4.3 : PGP Services

1. Encryption

- The sender creates a message.
- PGP generates a random number that is used as symmetric key to encrypt it.
- The symmetric key is encrypted using receiver's public key.
- Encrypted message and the encrypted symmetric key are sent to the receiver.
- The receiver decrypts the encrypted symmetric key using her private key.
- Once the receiver gets the symmetric key after decryption, the key can be used to decrypt the message.

Fig. 5.4.4 illustrates steps involved in encryption followed by PGP.

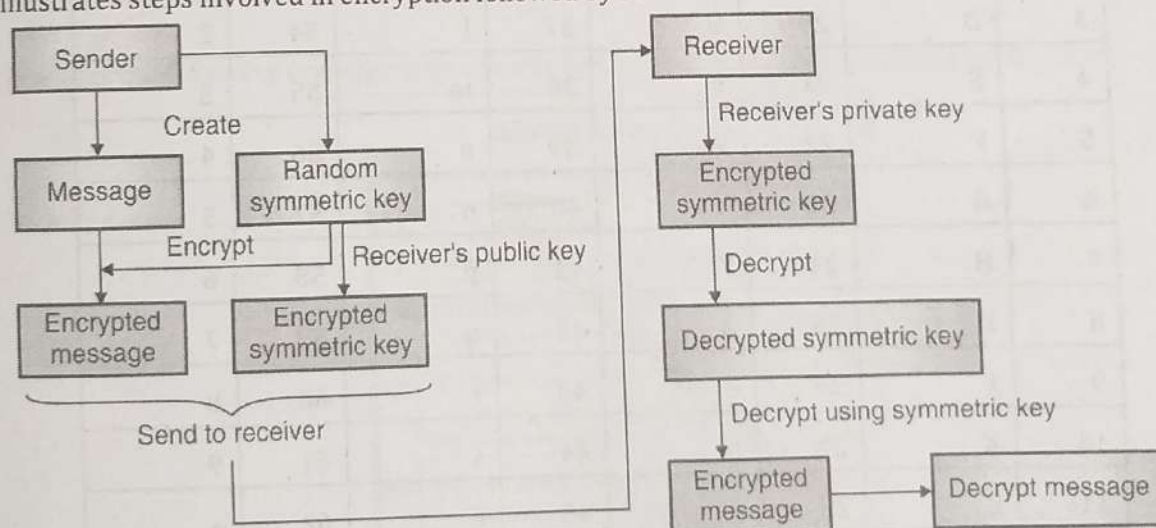


Fig. 5.4.4 : PGP Encryption / Decryption Process

- Digital Signature** : The digital signature uses a hash code or message digest algorithm, and a public-key signature algorithm. You have already learnt digital signature in detail in Chapter 2. Refer it for a quick refresher.
- Compression** : PGP compresses the message after applying the signature but before encryption. Compression has the added side effect that some types of attacks can be avoided by the fact that even the slightly altered, compressed data does not decompress without errors. This side security benefit is operationally useful.

4. **Radix-64 conversion** : R64 conversion is useful for compatibility of emails across varied systems. PGP's underlying native representation for encrypted messages, signature certificates, and keys is a stream of arbitrary octets. Some systems only permit the use of blocks consisting of seven-bit, printable text.

So, for transporting PGP's native raw binary octets through channels that are not safe to raw binary data, a printable encoding of these binary octets is needed. PGP provides the service of converting the raw 8-bit binary octet stream to a stream of printable ASCII characters, called Radix-64 encoding.

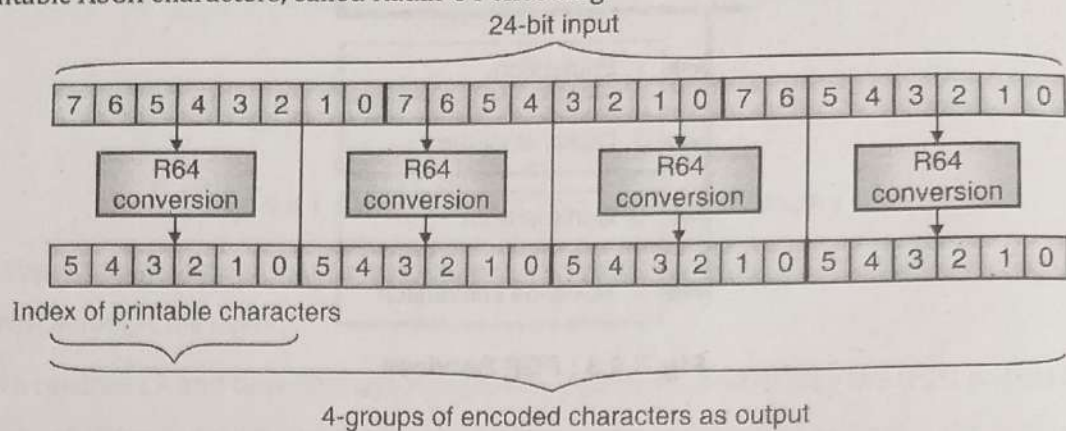


Fig. 5.4.5 : Radix-64 encoding

Each 6-bit group is used as an index into an array of 64 printable characters as shown in Table 5.4.1.

Table 5.4.1 : Encoding Map

Value	Encoding	Value	Encoding	Value	Encoding	Value	Encoding
0	A	17	R	34	i	51	z
1	B	18	S	35	j	52	0
2	C	19	T	36	k	53	1
3	D	20	U	37	l	54	2
4	E	21	V	38	m	55	3
5	F	22	W	39	n	56	4
6	G	23	X	40	o	57	5
7	H	24	Y	41	p	58	6
8	I	25	Z	42	q	59	7
9	J	26	a	43	r	60	8
10	K	27	b	44	s	61	9
11	L	28	c	45	t	62	+
12	M	29	d	46	u	63	/
13	N	30	e	47	v	(pad)	=
14	O	31	f	48	w		
15	P	32	g	49	x		
16	Q	33	h	50	y		

5.4.1(B) PGP Algorithms

The Table 5.4.2 is a summary of various PGP services and algorithms they support.

Table 5.4.2 : Summary of various PGP services and Algorithms

PGP Service	Supported Algorithm	Purpose
Public Key	RSA	Encrypt or Sign (Symmetric Key)
Public Key	Elgamal	Encrypt (Symmetric Key)
DSA (Digital Signature Algorithm)	DSS	Sign (Message)
Symmetric Key	IDEA, TripleDES, CAST5, Blowfish, AES	Bulk encryption (message)
Hash	MD5, RIPEMD160, SHA1, SHA256, SHA384, SHA224, SHA512	Hashing
Compression	ZIP, ZLIB, BZip2	Compress messages

4.2 S/MIME

Definition : *S/MIME (Secure/Multipurpose Internet Mail Extensions) provides a consistent way to send and receive secure MIME data (emails).*

It is based on certificates (Public Key Cryptography) and works as you have learnt in previous sections and units.

4.2(A) S/MIME Services

S/MIME provides the following cryptographic security services for electronic messaging applications.

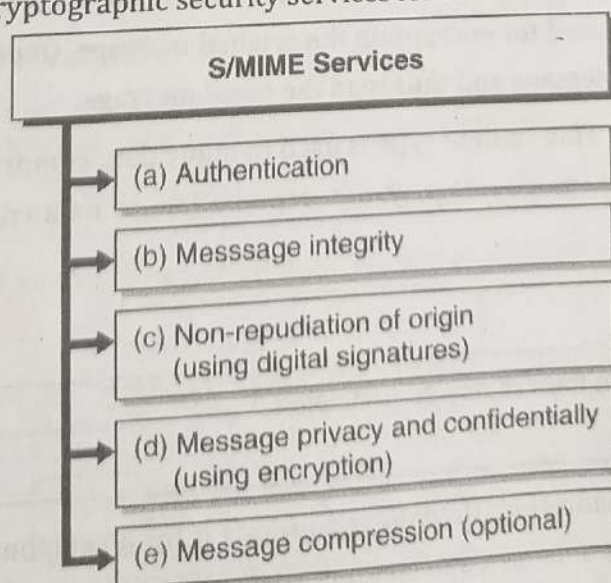


Fig. 5.4.6 : S/MIME Services

some techniques as you have learnt in the previous sections and units.

5.4.2(B) S/MIME Algorithms

Summary of various S/MIME services and algorithms they support are shown in The Table 5.4.3.

Table 5.4.3 : S/MIME Supported services and algorithms

Sr. No.	S/MIME Service	Supported Algorithms	Purpose
1.	Message Integrity	SHA-256, SHA-1, MD5	Hashing
2.	Non-repudiation, Authentication	RSA and DSA with Hashing algorithms	Digital Signature
3.	Key Encryption	RSA, RSAES-OAEP, Diffie-Hellman	Encrypting Symmetric key
4.	Privacy and Confidentiality	AES, DES, Triple DES	Message Encryption

5.4.2(C) S/MIME Cryptographic Message Syntax (CMS)

S/MIME standard describes a protocol for adding cryptographic signature and encryption services to MIME (email data). The MIME standard provides a general structure for the content of Internet messages and allows extensions for new content-type-based applications. The S/MIME specification defines how to create a MIME (email) body part that has been cryptographically enhanced according to the Cryptographic Message Syntax (CMS).

There are 4 types of CMS used in S/MIME :

- Data Content Type** : This is the original plaintext form of the email message. It has an identifier that is referred whenever it is compressed, encrypted or digitally signed.
- SignedData Content Type** : SignedData content type is used when a sender needs to apply a digital signature to a message. Applying a signature to a message provides authentication, message integrity, and non-repudiation of origin.
- EnvelopedData Content Type** : This content type is used to apply data confidentiality (via encryption) to a message. A sender needs to have access to a public key (for encrypting the symmetric key used for actual encryption of the message) for each intended message recipient to use this service. At the receiver's end, the receiver uses her private key to decrypt the symmetric key used for encrypting the original message. Once the symmetric key is available, it can be used to decrypt the encrypted message and thus read the email message.
- CompressedData Content Type** : This content type is used to apply data compression to a message. This content type does not provide authentication, message integrity, non-repudiation, or data confidentiality. It is only used to reduce the size of the message.

5.4.3 Firewalls

Q. What is a firewall ? What are the firewall design principles ?

MU - May 16, 5 Marks

Q. What are firewalls ?

MU - Dec. 16, 3 Marks

Your computer is connected to the internet. How do you protect it from someone trying to access it over the internet? How do you prevent some rogue programs on your computer to send information to the attacker? Firewalls could be a mechanism.

Definition : Firewalls are network security systems that protect the computing resources on a trusted network from unauthorized access.

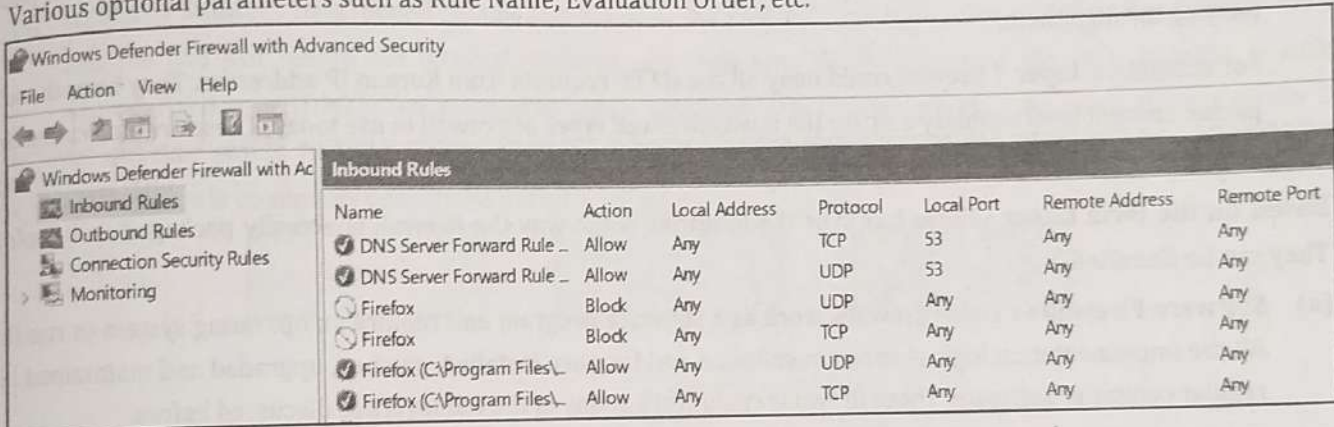
For example, you can access google.com website but not it's webserver's operating system. If you try connecting to the webserver except over the HTTP or HTTPS, the connection would be denied. That's what a firewall does at a high level.

You need to define various rules, as per your security requirements, in the firewall and the firewall evaluates those rules before granting or denying access to the requested resource.

5.4.3(A) Components of a Firewall Rule

Typically, a firewall rule consists of the following parameters :

1. Source IP address or hostname.
2. Destination IP address or hostname.
3. Source Port number.
4. Destination Port number.
5. Direction of communication [inbound or outbound].
6. Protocol name [TCP, UDP, ICMP or various others].
7. Action [allow, deny, log, etc.].
8. Various optional parameters such as Rule Name, Evaluation Order, etc.



Windows Defender Firewall with Advanced Security

File Action View Help

Windows Defender Firewall with Advanced Security

- Inbound Rules
- Outbound Rules
- Connection Security Rules
- Monitoring

Name	Action	Local Address	Protocol	Local Port	Remote Address	Remote Port
✓ DNS Server Forward Rule ...	Allow	Any	TCP	53	Any	Any
✓ DNS Server Forward Rule ...	Allow	Any	UDP	53	Any	Any
○ Firefox	Block	Any	UDP	Any	Any	Any
○ Firefox	Block	Any	TCP	Any	Any	Any
✓ Firefox (C:\Program Files\...	Allow	Any	UDP	Any	Any	Any
✓ Firefox (C:\Program Files\...	Allow	Any	TCP	Any	Any	Any

This is a snapshot of Microsoft® Windows® Firewall.

5.4.3(B) Classification of Firewalls

Q. Explain the different types of firewalls and mention the layer in which they operate.

MU- Dec. 16, 7 Marks

Q. What are the types of firewalls ?

MU- May 17, 5 Marks

Firewalls can be classified based on various attributes. Let's learn about their types.

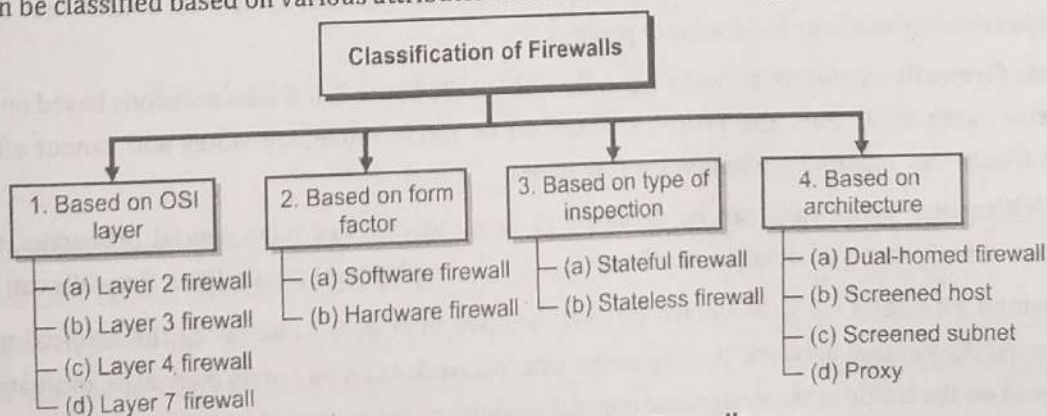


Fig. 5.4.7 : Classification of Firewalls

1. **Based on the OSI Layer :** As you understand, OSI is a conceptual networking model. Based on the various layers, firewalls can be classified as following :

- (a) **Layer 2 Firewall :** These firewalls work at the "Data Link" layer of the OSI model. These firewalls require MAC, VLAN or device hardware level information to operate. One of the greatest advantage of these types of firewalls is that they are not IP dependent.
- (b) **Layer 3 Firewall :** These firewalls work at the "Network" layer of the OSI model. These filter traffic based on source/destination IP, port, and protocol. These are one of the most prevalent types of firewalls in use today. These are also called as Stateless firewalls. These are also called first-generation firewalls.
- (c) **Layer 4 Firewall :** These firewalls work at the "Transport" layer of the OSI model. These firewalls do everything that a Layer 3 firewall does and additionally track the active network connections and allow/deny traffic based on the state of those connections. These can effectively stop DoS attacks such as the ones based on TCP SYN/ACK. These are aware of the state of connection. These are also called as Stateful firewalls. These are also called second-generation firewalls.
- (d) **Layer 7 Firewall :** These firewalls are called Layer 7 but can work at three layers – Session, Presentation and Application. For simplicity, these are just called Layer 7 firewalls. Layer 7 firewalls do everything that a Layer 3 firewall does and additionally include the ability to intelligently inspect the contents of the network packets passing through them.

For example, a Layer 7 firewall could deny all the HTTP requests from Korean IP addresses. They have the actual packet content level visibility and are the most advanced types of firewall in use today. These are also called third-generation firewalls.

2. **Based on the form factor :** Form factor or the footprint is the way the firewall is actually packaged and deployed. They can be classified as,

- (a) **Software Firewalls :** These firewalls work as a software program and require an operating system to run them. All the implementation logic is coded in software and they are installed, patched, upgraded and maintained like regular computer software. These firewalls could work at any of the OSI layers as discussed before.
- (b) **Hardware Firewalls :** Firewalls can also be deployed as a hardware device. Hardware firewall may have better performance and they come packaged in a ready to use hardware device. Like any other firewall, you need to configure it as per your security requirements.

3. **Based on the type of inspection :** Firewalls can keep track of connections or just work based on the configured rules. Based on their inspection types, these can be classified as,

- (a) **Stateful Firewalls :** These firewalls keep track of the state of connections apart from the defined firewall rules. These precisely understand various handshake protocols and can effectively stop attacks that try to manipulate connection establishment or maintenance process.
- (b) **Stateless Firewalls :** Stateless firewalls typically work at the Layer 3 and take decisions based on the defined rule parameters such as IP, Port and Protocol. These do not track connection states and cannot effectively protect against attacks that manipulate connection processes.

4. **Based on architecture :** Firewalls can be deployed in many ways. They have special properties that make them suitable for one deployment type over the another. Based on the deployment possibilities, firewalls can be classified as

- (a) **Dual-homed Firewalls :** A Dual-Homed Firewall has two interfaces - one facing the external network and the other facing the internal network. It receives the external packets on one of its interfaces, evaluates firewall rules and passes on the traffic to the designated internal resources via the second interface. The two interfaces are kept separate to isolate the external traffic with the internal traffic physically.

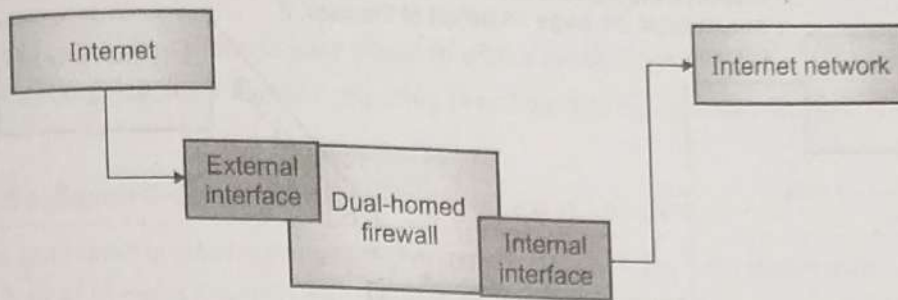


Fig. 5.4.8 : Dual-homed Firewalls

- (b) **Screened Host** : In a screened host firewall, all internet (and other regulated) traffic goes through the firewall, no matter what. The internet router device first screens (filters) all the packets that are relevant to the network and then passes it to the Screened Host firewall for further inspection and applying rules.

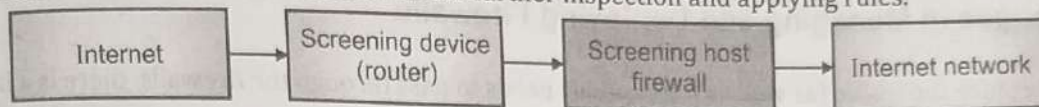


Fig. 5.4.9 : Screened Host

- (c) **Screened Subnet** : In screened subnet architecture, two firewalls are used. One just after the external network and the one just before the internal network. Any network that lies between the two firewalls is called a demilitarized zone (DMZ). You place your public facing servers such as web servers, email servers etc. in DMZ. An attacker would have to bypass both the firewalls before she can hit the internal network. This kind of architecture is commonly used in the industry today.

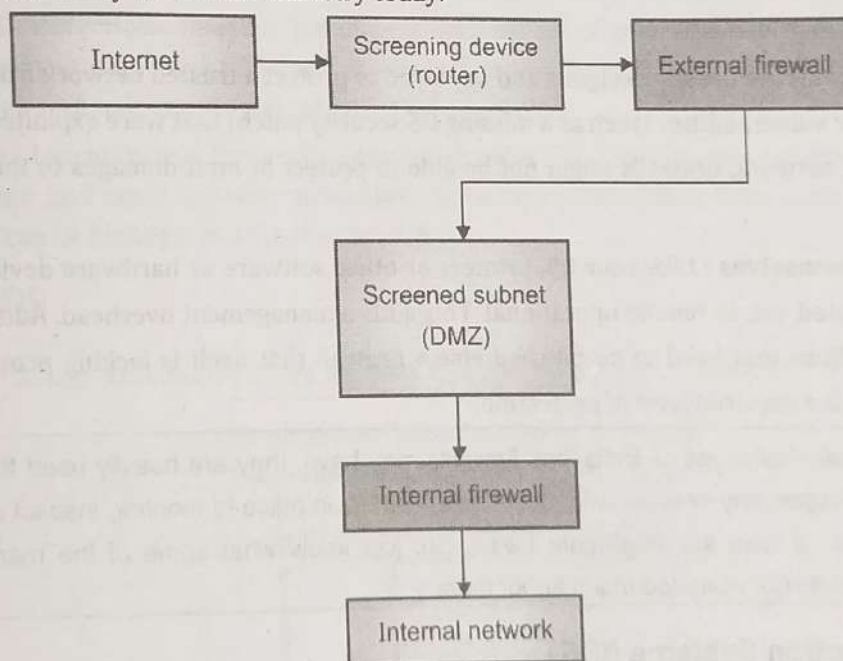


Fig. 5.4.10 : Screened Subnet

- (d) **Proxy firewall** : A proxy firewall stands between the trusted and the untrusted network and takes allow or deny decisions after careful inspection of what is being passed along. Like a regular proxy, the proxy firewall breaks the connection between the source and the destination. After examining the traffic, it self-establishes a connection with the destination and passes the intended traffic to the destination as if the packets were originating from it.

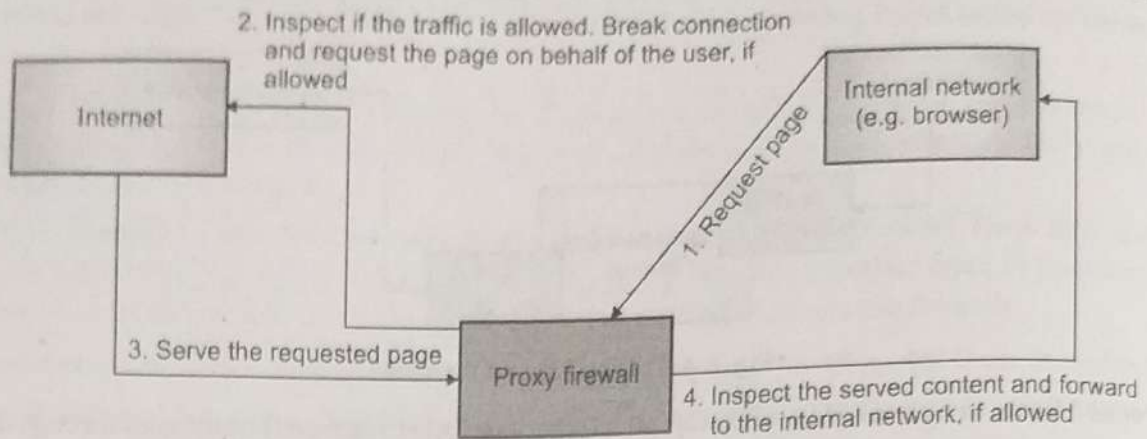


Fig. 5.4.11 : Proxy Firewall

5.4.3(C) Challenges in Managing and Deploying Firewalls

- 1. Performance :** Since the traffic (as well as the content) needs to pass through the firewalls, there is a little performance degradation of the network. The adequate traffic examination may add up to a few milliseconds of latency on each packet.
- 2. Business agility :** Firewall rules are usually manually added, edited or deleted. The pace of business might be too high to require several changes to the firewall rules frequently. Keeping up with these changes without making errors is difficult.
- 3. Costs :** Modern (or advanced) firewalls that provide content and protocol level inspection may be cost-prohibitive for small or medium sized organizations.
- 4. Insider attacks :** Firewalls are usually designed and deployed to protect a trusted network from an untrusted network. But, if there were other vulnerabilities (such as a missing OS security patch) that were exploited such that an attacker is already on the trusted network, firewalls might not be able to protect or limit damages to the other resources on the trusted network.
- 5. Managing firewalls themselves :** Like your OS, printers or other software or hardware devices, firewalls need to be installed, patched, updated, etc. to remain operational. This adds a management overhead. Additionally, firewalls could have known vulnerabilities that need to be patched else a firewall that itself is lacking protection may not be very useful in providing you the required level of protection.

Note : Irrespective of what challenges or limitations firewalls may have, they are heavily used throughout the industry. You cannot just imagine any network without several firewalls in place to monitor, inspect and manage legitimate traffic and separate it from the illegitimate traffic. So, just know what some of the management or technical challenges are and do not worry too much about them.

5.4.4 Intrusion Detection Systems (IDS)

- Q.** Explain the significance of an Intrusion Detection System for securing a network.
- Q.** Write short notes on IDS.

MU - May 16, 6 Marks

MU - May 19, 4 Marks

Intrusion means to encroach (or to capture) a place. For example, suppose there is a vacant site and you manage to build a small hut there without seeking permission of the site owner, that is precisely what intrusion is. You, as an individual, are trying to intrude on someone's property.

5.4.4(A) Introduction

In digital terms, intrusion refers to the similar situation where the malicious code or attackers try to encroach (forcibly enter and capture) information systems without requiring permission of the system owner. An Intrusion Detection System (IDS) is defined as,

Definition : A software that helps to find out if a system is breached.

Note : Breach is a word used in information security domain to describe any form of attack or unauthorized actions. You can use this word to mean anything that refers to the undesired actions and outcomes with respect to information security.

So, in a nutshell, IDS can help you to find out if there were undesired actions or attacks carried out on your information systems. IDS works using various techniques as we will see later in this section. Note here that IDS does not help to prevent the attacks unlike anti-virus. It is only a system that can gather system information and find out if everything looks alright or not.

5.4.4(B) Need for IDS

IDS is one of the software-based security mechanisms that help to protect information system. At a high level, it is needed for the following reasons,

1. **Defense in Depth :** As you saw in the security architecture section, security is about minimizing the damage that can be possibly done. Defense in depth (or the layered approach) of security designing ensures that even if one of the controls is to fail, the overall security of the system would still be possibly healthy. IDS fulfils this need to bring an added layer of protection where any breaches or their possibilities can be identified quickly.
2. **Automate intrusion detection :** Imagine that you have a large set of machines, say 1,000 and more. How would you inspect each and every machine and find out if there were attacks or attempts to attack it? IDS helps you to automate this need and alert you when it detects any threat or likely a breach.
3. **Corrective actions :** Learning from threats or breaches that the IDS identifies, you can take corrective actions on your infrastructure design and could possibly strengthen its security. You might have some unprotected areas in your infrastructure that can be highlighted with the use of IDS.

5.4.4(C) Types of IDS

Broadly speaking, IDS can be classified based on **what** it monitors and **how** it monitors.

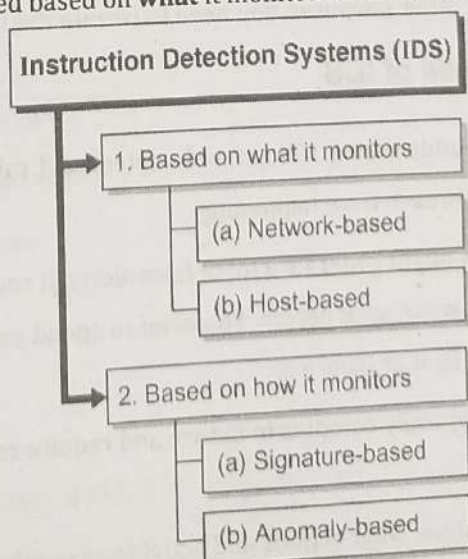


Fig. 5.4.12 : Types of IDS

1. **Based on what it monitors** : IDS can be classified into Network-based IDS (NIDS) and Host-based IDS (HIDS).
 - (a) **Network-based IDS (NIDS)** : Network-based IDS evaluate intrusions from the networking side. They watch all network traffic as it reaches the various information systems. If there are any alerting situations based on the network traffic analysis, it notifies the administrator to take the corrective actions. NIDS do not have visibility into what's actually going on within the information system. It can only watch and detect threats and breaches from the networking viewpoint.
 - (b) **Host-based IDS (HIDS)** : Host-based IDS are typically installed on the individual information systems and then they watch for suspicious activities occurring on the system. System entities such as system services and processes, system files, privileged user actions, downloads, etc. are closely monitored to detect any undesired activities. HIDS do not have visibility into what's going on at the networking side of the system. It can only watch and detect activities with respect to individual machines only.
2. **Based on how it monitors** : IDS can be classified into Signature-based and Anomaly-based.
 - (a) **Signature-based** : Like banks and other organizations use human signature to validate requests and transactions, similarly Signature-based IDS has a pre-loaded database of various attack signatures (patterns of a possible attack). When it watches the activities, it constantly compares the activities' patterns with that in the database. If a match is found, it raises an alert. If you notice, there are 3 things to understand here:
 - (i) Signature based IDS can only detect attacks if it already and historically knows about an attack pattern.
 - (ii) For new types of attack, signature-based IDS would not raise alerts.
 - (iii) It is important for you to update the signature definitions time to time (like how you do in anti-virus system).
 - (b) **Anomaly-based** : Anomaly typically means "deviation from routine". For example, if you wake up at 7 AM every day and one day you wake up at 4 AM, that is an anomaly situation. If I were to plot your wake-up time graph, 4 AM would show up away from your regular wake-up time. That 4 AM point on the graph is called outlier (or away from other samples).

Similarly, the Anomaly-based IDS first establishes the baseline (common routine) of activities. It might take up to 2-3 weeks to "learn" what's right for a system. Once the learning phase is over, it would watch out for any activities that are not part of that baseline and raise alerts. If you notice, there are 3 things to understand here as well :

 - (i) It does not require signature and hence can possibly detect new attacks.
 - (ii) It requires a learning period during which the system should have undergone all possible activities.
 - (iii) If you plan to use the system for other purposes, you need to retrain the IDS.

5.4.4(D) Limitations and Challenges of IDS

1. **Does not prevent attacks** : As you understand, IDS can only detect and raise alerts when it finds a likelihood of a breach. It cannot prevent or block the breach from happening.
2. **High rate of false alerts (noise)** : IDS might generate a lot of false alerts. It could happen so for example, when there is a new traffic from a source that IDS has not seen before. You need to spend your resources to take a note of each alert and appropriately deal with it – either fix it or ignore it.
3. **Complex systems** : IDS systems are typically complex in nature and require regular administrative actions and tuning for adequate operations.
4. **Bypassing IDS** : Advanced attackers know what actions and activities a version and brand of IDS can detect and what not. They tune their activities to bypass such detection mechanisms and go undetected.

```
iamahacker%n
Original value of test:5
iamahacker
New value of test:10
```

6.3.2(C) Integer

The integer overflow can occur when you take integer inputs but their processing results into larger values than the variable can hold.

Let's see an example.

```
#include <stdio.h>

void main(void)

{
    unsigned short i = 60000;
    unsigned short j = 50000;
    unsigned short result = i * j;
    printf ("%d",result);
}
```

Unsigned short data type can hold 2 bytes up to the numbers 0 to 65,535. In the given example, both the variables are under the limit of what unsigned short can hold but the result of their multiplication is too large to be accommodated in an unsigned short variable. This results in memory fault and incorrect result.

24064

...Program finished with exit code 5

6.4 SQL Injection (SQLi)

Q. Explain briefly with example, how the SQL injection attack.

MU - Dec. 17, 3 Marks

Definition : SQL Injection (SQLi) is a vulnerability exploiting which an attacker can inject malicious SQL commands and cause the database server to execute them.

Using SQLi, the attacker can,

- Read sensitive and unauthorised data from the database,
- Modify data,
- Execute administrative commands on the database,
- And can also Issue commands to the operating system running the database,

Note here that the presence of SQLi attack does not mean that the SQL databases are inherently vulnerable or exploitable directly. This exploit only works if the application developer has programmed the application in such a way that the attack is possible. SQL databases just behave as they should. So, even if the attack is called SQLi, the fix for this exploit is not in the SQL databases. The fix is required in the application developer's code as we will see later on.

SQLi is proven to be one of the most dangerous and impactful exploits on database-based applications. It has maintained the first position in the OWASP's list of Top Ten Most Critical Application Security Risks from several years.

https://www.owasp.org/index.php/Category:OWASP_Top_Ten_Project

OWASP Top 10 - 2013	→	OWASP Top 10 - 2017
A1 – Injection	→	A1:2017-Injection
A2 – Broken Authentication and Session Management	→	A2:2017-Broken Authentication
A3 – Cross-Site Scripting (XSS)	→	A3:2017-Sensitive Data Exposure
A4 – Insecure Direct Object References [Merged+A7]	U	A4:2017-XML External Entities (XXE) [NEW]
A5 – Security Misconfiguration	→	A5:2017-Broken Access Control [Merged]
A6 – Sensitive Data Exposure	→	A6:2017-Security Misconfiguration
A7 – Missing Function Level Access Contr [Merged+A4]	U	A7:2017-Cross-Site Scripting (XSS)
A8 – Cross-Site Request Forgery (CSRF)	⊗	A8:2017-Insecure Deserialization [NEW, Community]
A9 – Using Components with Known Vulnerabilities	→	A9:2017-Using Components with Known Vulnerabilities
A10 – Unvalidated Redirects and Forwards	⊗	A10:2017-Insufficient Logging&Monitoring [NEW,Comm.]

6.4.1 How does SQLi Work?

Q. With the help of examples explain non malicious programming errors.

MU - Dec. 15, 5 Marks

There could be several non-malicious programming errors such as buffer overflow, SQL Injection, Cross-site scripting etc. that can be exploited by attacker. Let's take an example of SQL Injection (SQLi).

SQLi can potentially be exploited where the user input is directly used to form SQL database queries. Instead of providing the expected input, the attacker can provide malicious input such that the original and desired SQL query is changed. The attacker can control the behaviour of the SQL queries and can manipulate what SQL queries are run.

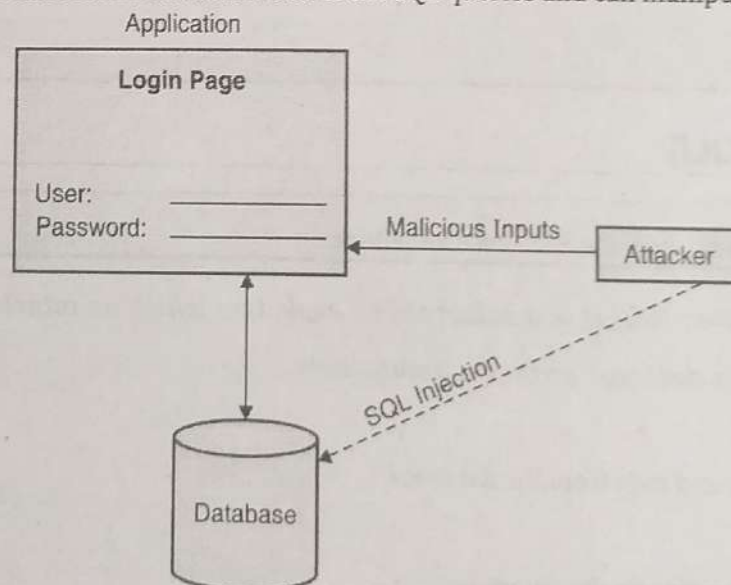


Fig. 6.4.1 : SQL Injection

Let's see an example.

```
query = "SELECT * FROM users WHERE name = ' + userName + ';"
```

This query takes *userName* from the user. If the user passes a valid input such as Joe as the *userName*, the query statement is correctly formed as following.

```
query = "SELECT * FROM users WHERE name = ' + Joe + ';"
```

```
query = "SELECT * FROM users WHERE name = 'Joe';"
```

But what if the user is malicious and passes 'OR '1'='1 as input?

```
query = "SELECT * FROM users WHERE name = ' + ' OR '1'='1 + ';"
```

```
query = "SELECT * FROM users WHERE name = " OR '1'='1';"
```

So, what happened here?

The *name* variable is searched for blank (' ') and then there is an *OR* statement which will always evaluate to True. ('1'='1'). So, overall, the SQL query formed will always run and print the entire *users* table!

So, the intention of the developer was to get the user name from the user and populate that value to form the dynamic query which can then show that particular user's details. But the malicious input provided by the user resulted in forming a query that would print the entire table and disclose the details of all the users contained in the database.

Let's consider some other malicious inputs.

```
OR '1'='1 --
```

```
OR '1'='1 {
```

```
OR '1'='1 /*
```

In SQL, you can provide comments using -- (double hyphen), { } (braces) or /*...*/ (C-style multi-line comments). An attacker can pass injection statements followed by comments. Then the rest of the query is not executed, and the attacker can only execute the part of the query she wishes to execute.

Let's take the following query as an example.

```
query = "SELECT * FROM users WHERE
        username = ' + username + '
        AND password = ' + password + ';"
```

In this example, the system is trying to authenticate the user by taking the user name and the corresponding password. So, if the user name is valid and the password entered is also valid, the query will return the result else it will not return any results.

Now, an attacker can pass the input as 'OR '1'='1';' -- for *username* and any random value for *password*.

```
query = "SELECT * FROM users WHERE
        username = " OR '1'='1';" -- '
        AND password = ' + password + ';"
```

Such a malicious input comments out the password check in the SQL query and returns True. The user is successfully authenticated bypassing providing any user name or password.

The attacker can also add more SQL queries as malicious input. For example, consider the following query.

```
query = "SELECT * FROM users WHERE
        username = " OR '1'='1'; DROP table users;" -- '
        AND password = ' + password + ';"
```


The malicious input of 'OR '1'='1'; DROP table users; -- can now not only authenticate the user but also can delete the table containing the user information.

6.4.2 Types of SQLi

There are several variants of SQLi.

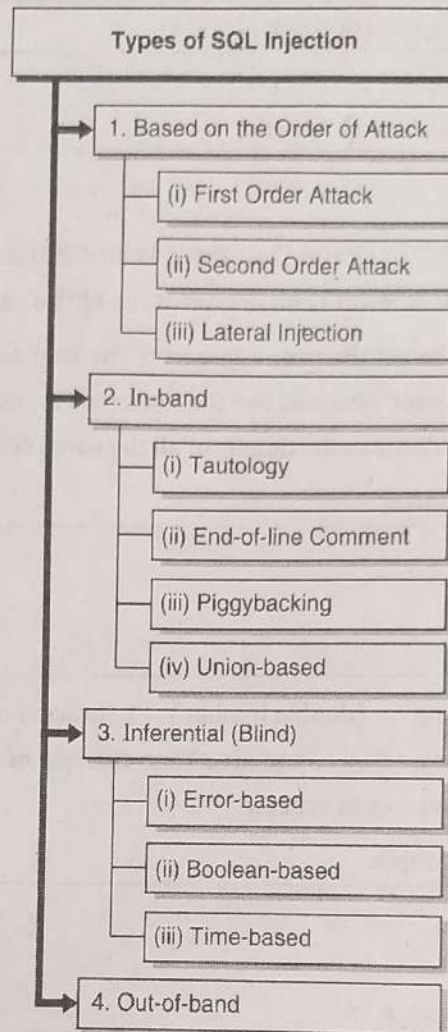


Fig. 6.4.2 : Types of SQL injection

6.4.2(A) Based on the Order of Attack

1. First order attack

Definition : In the first order attack, the attacker enters a malicious input and causes the SQLi attack immediately.

The injected malicious SQL query is run immediately, and the attacker gets the results. The SQLi examples that you have learnt in the previous section are all first order attacks. A single query is manipulated, and the results are immediately obtained.

2. Second order attack

Definition : In the second order attack, the attacker first injects the malicious query (or data) into the database and then gets that malicious query (or uses the malicious data) subsequently executed by another activity directly from the database.

The result of second order SQLi attack is not obtainable immediately. There might be some time elapsed between the time at which the malicious query (or the malicious data) is injected and the time when the malicious query is actually executed (or malicious data is actually used), and the result of the attack is seen.

Let's see an example.

```
INSERT INTO users(username, password) VALUES("admin--", "random");
UPDATE users SET password = '1' WHERE username = admin--
```

Usually there are two SQLi attacks done.

First, the attacker manages to insert a new user into the database (using the first order attack that you learnt earlier or by just following the process of creating a new account on the system). Note here that the user name added is specifically having -- at the end of it, but since it is passed inside " ", the SQL query will accept that as the value and insert it into the database without complaining.

In the second statement, the attacker wishes to reset her password for *admin--* account she created. She passes *admin--* as the user name whose password needs to be reset. The database executes the query but due to -- at the end of *admin--*, it actually resets the password of the original *admin* user. Now, since the password of the original admin user is reset, the attacker can login as the admin on the system.

So, as you learnt in the example, there were two parts to the SQLi. First a value was stored in the database and then that stored value was exploited to carry out the SQLi.

3. Lateral Injection

Definition : In Lateral Injection, the attacker modifies the system functions to inject malicious query.

Using Lateral SQL Injection, an attacker can exploit stored procedure (SQL functions). For example, the function *TO_CHAR()* can be manipulated by changing the environment variables *NLS_Date_Formator* *NLS_Numeric_Characters*. You can include any text in the format model and can exploit SQLi.

6.4.2(B) In-band

1. Tautology

Tautology means a statement that is always true. For example, "a beginner who has just started" is a tautology.

Definition : Tautology is a form of SQLi where conditional statements are injected that always evaluate to true.

Following is a simple example of a tautology.

```
SELECT * FROM users WHERE username=" or 1=1 --
```

The use of `1 = 1 --` makes the entire *WHERE* condition as a tautology (always evaluating to true).

2. End-of-line Comment

Definition : End-of-line comment is a form of SQLi where comments are used to terminate the SQL query prematurely (inappropriately) to run only a part of the query.

Following is a simple example.

```
SELECT * FROM users WHERE username='admin'-- AND password = adminpasswd
```

The use of -- terminates the query prematurely and the query thus returns the entire details of the *admin* user without requiring the *admin* password.

3. Piggybacking

Piggybacking means to ride on someone's shoulder.

Definition : Piggybacking is a form of SQLi where additional queries are injected to run with the original query.

Following is a simple example.

```
SELECT * FROM users WHERE username = 'admin' OR '1'='1'; DROP table users;
```

The use of ; after the first query allows to add the second query. When the first query completes, the database server runs the second query followed by the ; (*DROP table users*). The attacker can add as many queries as she wishes separately.

4. Union-based

The UNION operator is used to combine the result-set of two or more SELECT statements.

Definition : Union-based is a form of SQLi where the UNION operator is used to inject the second query to the original query.

Following is a simple example.

```
SELECT username FROM users where username = '' OR '1'='1'
UNION SELECT empname FROM employees
```

There are two tables *users* and *employees*, and both have a field containing names. The attacker can use the UNION operator to reveal the employee names from the *employees* table.

6.4.2(C) Inferential (blind)

1. Error-based

Definition : Error-based is a form of SQLi where the attacker causes errors to learn about the environment.

For gathering information about the environment such as database type, version, OS, table names, etc. the attacker might cause system errors by injecting random queries. If those errors are not sufficiently handled in the application, those errors would be visible in the application. The attacker can use the gathered information to launch more sophisticated and known attacks.

Following is a simple example.

```
SELECT * FROM users WHERE username = '' AND pin=convert(int,(select top 1 name from sysobjects where xtype='u'))
```

Here the attacker purposely creates an error by trying to convert name into integer. *sysobjects* is a system table that stores all the table names present on the database server. The attacker tries to check the table names starting from the first entry (*top 1*) in the *sysobjects* table. The attacker is only interested in the tables created by the user (*xtype='u'*).

The query when executed gives the following error.

```
Microsoft OLE DB Provider for SQL Server (0x80040E07)
Error converting nvarchar value 'CreditCards' to a column of data type int
```

The attacker gets to know two things from this error :

- The database server running behind the application is Microsoft® SQL Server®
- There is a table by name CreditCards present on the database server.

The attacker can then use this information to launch further attacks.

2. Boolean-based

Definition : Boolean-based is a form of SQLi where the attacker injects true/false statements to learn about the environment.

Following is a simple example.

Suppose the attacker injects the condition such that it always evaluates to true.

```
SELECT * FROM users WHERE username='' or 1=1 -- AND password = mypasswd
```

Suppose the response from the application is "Invalid Password".

The attacker can infer (guess) two things from it:

- Either her malicious input was detected and rejected.
- Or the check for password is a separate query (because -- would have commented out that password check).

Now, suppose the attacker changes the condition such that it always evaluates to false.

```
SELECT * FROM users WHERE username='' or 1=0 -- AND password = mypasswd
```

Suppose the response from the application is "Invalid Username and Password".

The attacker learns that the response is different from the previous one when she inserted a true condition.

This would conclude that the field *username* is injectable and could be exploited.

3. Time-based

Definition : Time-based is a form of SQLi where the attacker injects random queries and evaluates the time it takes to run the query and get the result to learn about the environment.

Time-based SQLi injects the SQL query to the database such that it forces the database to wait for a specified amount of time (in seconds) before responding. The response time indicates to the attacker whether the result of the query is true or false.

Following is a simple example.

```
SELECT accounts FROM users WHERE login='abc' and
ASCII(SUBSTRING((select top 1 name from sysobjects),1,1)) > X WAITFOR 5 -- ' AND
pass='' AND pin=0
```

In this example, the attacker waits for 5 seconds if the ASCII code of the first character from the first table name in *sysobjects* is greater than the ASCII code of the character X. If the ASCII code is greater, then there would be a 5 second delay and if the ASCII code is not greater, then there would not be a 5 second delay.

6.4.2(D) Out-of-band

Definition : Out-of-band is a form of SQLi where the attacker injects the SQL query via one medium and receives the results via another medium.

It is not very common because it depends on the features enabled on the database server such as the ability to send emails or notifications. Out-of-band techniques offer the attacker alternatives for evaluating attack results.

For example, the administrator may choose to set a logic bomb such that if she does not deactivate it before a time, automatically the system is infected.

8. **Trojan Horses** : These are malicious programs that hide themselves in legitimate (right) looking programs. For example, a trojan might be called notepad.exe. When you double click it, it might call the original notepad.exe program but also do several other things such as sending sensitive information to the attacker's machine. You believe that the program you clicked is legitimate and is doing a good and desired action, but it is actually carrying out malicious activities behind the scene without your knowledge.
9. **Ransomware** : Ransomware is the most recent type of malicious code. In this, the attacker takes over the user's system and locks it out and demands a ransom (a large sum of money) for unlocking it. If the user does not pay the money, the attacker usually erases the complete system and the user may never recover the system and data that was on it.

Table 6.5.1 : Comparison of Various Malicious Code

Type of malware	Purpose	Trigger	Replication	Countermeasure
Virus	Deliver payload	User action required	User action required	Anti-virus
Worms	Deliver payload	User action not required	User action not required	Anti-virus
Rootkits	Future access	Attacker uses these tools	Not applicable	Anti-virus
Spyware	Gather sensitive information	User action not required	Not applicable	Anti-malware
Adware	Serve advertisements	User action not required	Not applicable	Anti-malware
Botnets	Deliver payload	By botnet master	In thousands to form a network	Anti-malware
Logic bombs	Deliver payload	User action not required	Not applicable	Separation of duties
Trojan Horse	Deliver payload	User action not required	Not applicable	Anti-virus
Ransomware	Extort money	By the attacker	Not applicable	Backup of data

Now that you have an overall idea of malware, let's dive deeper into some of them.

6.5.2(A) Virus and Worms

Q. Write a brief on - Viruses and their types.

MU - Dec. 15, 5 Marks

Q. What are the different types of viruses and worms? How do they propagate?

MU - Dec. 16, 10 Marks

What is a virus?

***Definition** : Virus is a category of malicious code that cannot self-replicate itself to deliver the payload.*

It requires a trigger (user action) to activate and then deliver the payload (harm the system in a particular way). It could deliver various payloads such as deleting system files, displaying specific messages or stealing information. ILOVEYOU and Melissa are two well-known viruses.

What is a worm?

Definition : Worms are smaller malicious programs that can self-replicate and trigger without needing a user action.

They are targeted towards infecting the systems and delivering the required payload of their own. One of the most common examples of worm is Stuxnet which was used to damage Iran's uranium infrastructure.

Types of virus

Viruses are usually classified based on :

1. How they live in memory
2. How they spread
3. How they hide
4. What they deliver

Let us understand the classification first. We will then detail them out.

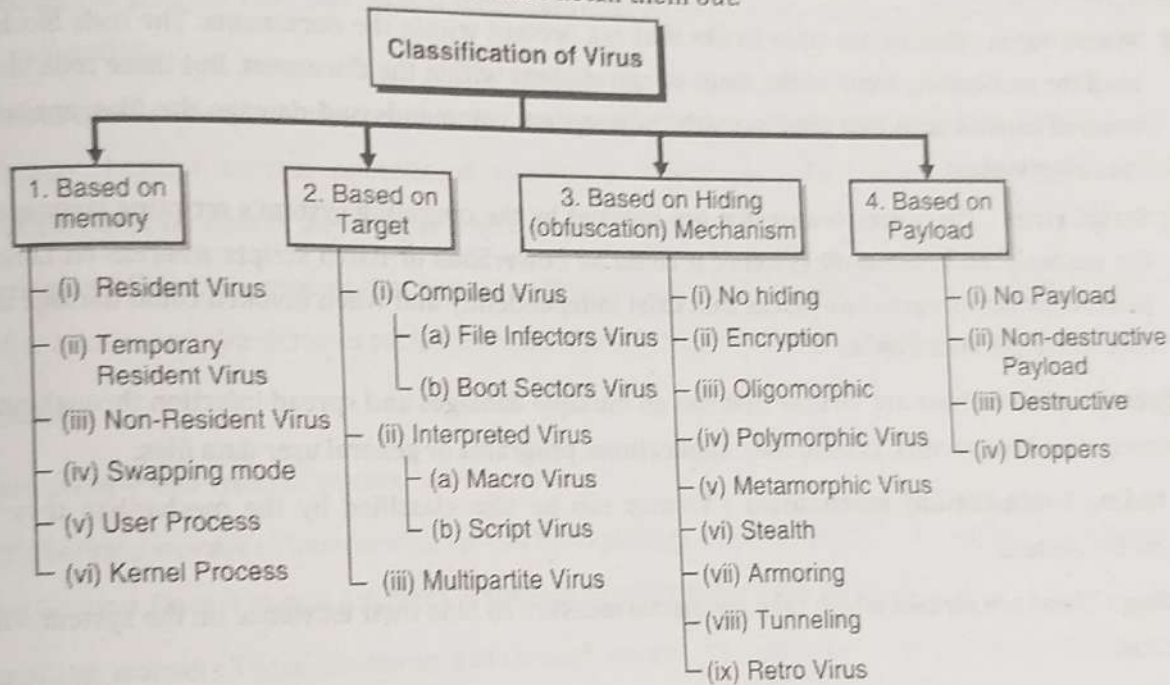


Fig. 6.5.2 : Classification of Virus

1. **Based on memory :** This classification depends upon how the virus stays within a system.

(a) **Resident virus :** These types of viruses stay in memory and infect any file or program that is opened.

(b) **Temporary resident virus :** These viruses stay in memory for some time and then vacate the memory based on time or after some event (say infecting 5 files).

(c) **Non-resident virus :** These viruses do not stay in memory. These infect the files by copying their payloads to the files directly. The relevant files are searched and then the payload is copied to them.

(d) **Swapping mode :** These viruses use swap space for residing. These switch from swap space to memory, infect a few files and return back to the swap space.

(e) **User process :** These viruses run with user level access and privileges. These can mostly infect only the user files without touching the system files (since for infecting system files, administrative level access is needed).



- (f) **Kernel process** : These viruses are very dangerous as they get installed at the system level (say via device drivers or through system applications). These viruses run with the full administrative access and privileges and can infect any file, program or application on the system.
2. **Based on target** : This classification depends upon what the virus chooses to infect (the target of infection).
- (a) **Compiled virus** : These are viruses that run as machine executable. These are directly run by the operating system. The virus' source code is compiled to form an executable file. These can be further classified into,
- (i) **File Infector virus** : File infectors corrupt the specific types of files. These often manipulate the file headers such that when the file is opened, it actually places the file pointer to the malware code execution point.
 - (ii) **Boot sector virus** : These viruses infect the boot sectors on the hard disk. Boot sectors are key partitions that help to power on and bring up the system for operation.
- (b) **Interpreted virus** : The source code of the interpreted viruses is run at the execution timeline by line. Unlike compiled viruses, the interpreted viruses are run by the legitimate application programs when invoked. These are further classified into,
- (i) **Macro virus** : Macros are code blocks that are present within the documents. The code blocks are usually used for automating some of the steps or calculations within the document. But these code blocks could be infected as well such that they run arbitrary system commands and damage the files, applications or the operating system.
 - (ii) **Script virus** : These are viruses that are invoked by the operating system's scripting language interpreter. For example, on Windows® systems, it could be PowerShell or Batch scripts whereas on Linux it could be shell script. Scripts are code blocks that exist independently and when invoked could damage the system or files and applications on it.
- (c) **Multipartite virus** : These are viruses that can do multiple damages and spread infection throughout the system. These can infect boot sectors, system files, applications, programs or general user data files.
3. **Based on hiding (obfuscation) mechanism** : Viruses can be also classified by the mechanism they use to hide themselves on the system.
- (a) **No hiding** : These are viruses which take no special measure to hide their existence on the system. Viruses rarely follow this.
 - (b) **Encryption** : These viruses use encryption to hide themselves. They have a decrypt program which exposes the virus when it's time to spread the infection on the system. Once the infection task is carried out, the virus again encrypts itself to hide.
 - (c) **Oligomorphic** : These are also called semi-polymorphic. Basically, these viruses use several decryption routines to hide itself as much as possible. With each infection, it changes the decryption routines to avoid getting detected by the anti-virus tools.
 - (d) **Polymorphic** : These viruses have some sort of mutation (changing) engine that changes the appearance of the viruses with each infection to make their detection very difficult. These make several changes to the encryption settings and also changes the decryption code accordingly.
 - (e) **Metamorphic** : These viruses change the virus body instead of appearance. It is done by using unneeded functions or commands or changing the order of virus code.
 - (f) **Stealth** : These viruses try to hide the infection by restoring the older properties of the file (time of modification, file size, etc.) after infection.

- (g) **Armoring** : An armoring virus is a virus that makes analysis very difficult. These viruses use various techniques to hide themselves from detection and removal.
- (h) **Tunnelling** : These viruses attach themselves to the system interrupts. Whenever there is an interrupt call, first the virus executes itself and then passes the control to the original interrupt.
- (i) **Retro virus** : These viruses are specifically designed to bypass any security tools such as firewall, anti-virus or intrusion detection systems. The virus developers understand to a great extent how such security programs work and make it increasingly hard for these programs to detect viruses.

4. **Based on payload** : Based upon what the viruses deliver or do to the target system, they can be classified as under.

- (a) **No payload** : These viruses do not affect systems as such or infect files. These are generally productivity killers that irritate by slowing down the system or creating minor nuisances.
- (b) **Non-destructive payload** : These viruses as well are non-harming in nature except that they pop up repeated messages or graphic. They can control some hardware devices such as mouse, keyboard or cdrom and make them to malfunction.
- (c) **Destructives** : These are viruses that are motivated to cause severe damage to the system such that they are damaged beyond normal operational conditions. These can affect boot sectors, system files, programs, applications, user data or anything else on the system.
- (d) **Droppers** : These are viruses that just sit on the system and let the attacker use the system's resources to launch other attacks and cybercrimes such as identity theft, DDoS, software piracy, etc.

Types of worms

There are majorly two types of worms.

1. **Network Service worms** : These worms spread by exploiting vulnerabilities in the network service associated with an OS or application. Once it infects a system, it spreads to other networked systems.
2. **Mass mailing worms** : These worms spread through emails. It reaches a system via an email, infects it and then looks for other email addresses in the system to send a copy of itself to other users.

Table 6.5.2 : Comparison between Virus and Worm

Comparison Parameter	Virus	Worms
Trigger	User action required	User action not required
Replication	User action required	User action not required
Spread	Mostly remains on the infected system	Spreads throughout the network
Countermeasures	Antivirus	Antivirus, Firewall
Detection Complexity	High	Medium
Damage Caused	Usually high	Usually medium

6.5.3 General Guidelines for Preventing Malware

Some of the most common and general guidelines for preventing any form of malware are as following.

1. Regularly scan your systems using an adequate anti-malware program
2. Do not open emails and attachments from unknown sources
3. Control the urge to click on every URL that you see
4. Restrict visiting sites that support software piracy, promise free videos, music, books, etc.
5. Do not install programs from unknown or non-reputed sources
6. Regularly update your OS and installed applications to fix any known vulnerabilities
7. Do not plug external devices such as a pen drive from unknown sources
8. Limit physical access to the system

Review Questions

Here are a few review questions to help you gauge your understanding of this chapter. Try to attempt these questions and ensure that you can recall the points mentioned in the chapter.

[A] Software Vulnerabilities

- Q. 1 With a simple code example, explain buffer overflow. (6 Marks)
- Q. 2 You are reviewing code written by a colleague. She has used gets() in her code. What do you suggest and why? (4 Marks)
- Q. 3 What can cause buffer overflow? (7 Marks)
- Q. 4 Write a short note on ASLR. (4 Marks)
- Q. 5 How Data Execution Prevention (DEP) can be used to provide protection from buffer overflow? (5 Marks)
- Q. 6 Classify buffer overflow protection techniques. (6 Marks)
- Q. 7 Julius is interested in buffer overflow protection. He comes to you asking about the advantages and disadvantages of OS-based and compiler-based protection mechanisms. What do you tell him? (6 Marks)
- Q. 8 What is a canary? How and where it is used? (6 Marks)
- Q. 9 Draw a block diagram of StackShield and explain. (6 Marks)
- Q. 10 Explain any three types of buffer overflow. (6 Marks)
- Q. 11 Write a short note on Format String vulnerability. (4 Marks)
- Q. 12 Compare the types of XSS. (6 Marks)
- Q. 13 Persisted XSS can exploit any visitor. Comment. (6 Marks)